What is phishing?



17 May 2024

Matthew Kosinski

Enterprise Technology Writer

What is phishing?

Phishing is a type of cyberattack that uses fraudulent emails, text messages, phone calls or websites to trick people into sharing sensitive data, downloading malware or otherwise exposing themselves to cybercrime.

Phishing attacks are a form of social engineering. Unlike other cyberattacks that directly target networks and resources, social engineering attacks use human error, fake stories and pressure tactics to manipulate victims into unintentionally harming themselves or their organizations.

In a typical phishing scam, a hacker pretends to be someone the victim trusts, like a colleague, boss, authority figure or representative of a well-known brand. The hacker sends a message directing the victim to pay an invoice, open an attachment, click a link or take some other action.

Because they trust the supposed source of the message, the user follows the instructions and falls right into the scammer's trap. That "invoice" might lead directly to a hacker's account. That attachment might install ransomware on the user's device. That link might take the user to a website that steals credit card numbers, bank account numbers, login credentials or other personal data.

Why phishing is a major cyberthreat

Phishing is popular among cybercriminals and highly effective. According to IBM's Cost of a Data Breach report, phishing is the most common data breach vector, accounting

for 15% of all breaches. Breaches caused by phishing cost organizations an average of USD 4.88 million.

Phishing is a significant threat because it exploits people rather than technological vulnerabilities. Attackers don't need to breach systems directly or outsmart cybersecurity tools. They can trick people who have authorized access to their target—be it money, sensitive information or something else—into doing their dirty work.

Phishers can be lone scammers or sophisticated criminal gangs. They can use phishing for many malicious ends, including identity theft, credit card fraud, monetary theft, extortion, account takeovers, espionage and more.

Phishing targets range from everyday people to major corporations and government agencies. In one of the most well-known phishing attacks, Russian hackers used a fake password-reset email to steal thousands of emails from Hillary Clinton's 2016 US presidential campaign.[1]

Because phishing scams manipulate human beings, standard network monitoring tools and techniques cannot always catch these attacks in progress. In fact, in the Clinton campaign attack, even the campaign's IT help desk thought the fraudulent password-reset emails were authentic.

To combat phishing, organizations must combine advanced threat detection tools with robust employee education to ensure that users can accurately identify and safely respond to scam attempts.

Types of phishing attacks

The word "phishing" plays on the fact that scammers use attractive "lures" to trick their victims, much the same way that fishers use bait to hook actual fish. In phishing, the lures are fraudulent messages that appear credible and evoke strong emotions like fear, greed and curiosity.

The kinds of lures phishing scammers use depend on whom and what they are after. Some common examples of phishing attacks include:

Bulk email phishing

In bulk email phishing, scammers indiscriminately send spam emails to as many people as possible, hoping that a fraction of the targets fall for the attack.

Scammers often create emails that appear to come from large, legitimate businesses, such as banks, online retailers or the makers of popular apps. By impersonating well-known brands, scammers increase the chances that their targets are customers of those brands. If a target regularly interacts with a brand, they are more likely to open a phishing email that purports to come from that brand.

Cybercriminals go to great lengths to make phishing emails appear genuine. They might use the impersonated sender's logo and branding. They might spoof email addresses to make it seem like the message comes from the impersonated sender's domain name. They might even copy a genuine email from the impersonated sender and modify it for malicious ends.

Scammers write email subject lines to appeal to strong emotions or create a sense of urgency. Savvy scammers use subjects that the impersonated sender might actually address, such as "Problem with your order" or "Your invoice is attached."

The body of the email instructs the recipient to take a seemingly reasonable action that results in divulging sensitive information or downloading malware. For example, a phishing link might read, "Click here to update your profile." When the victim clicks that malicious link, it takes them to a fake website that steals their login credentials.

Some scammers time their phishing campaigns to align with holidays and other events where people are more susceptible to pressure. For example, phishing attacks on Amazon customers often spike around Prime Day, the online retailer's annual sales event.[2] Scammers send emails about fake deals and payment problems to take advantage of people's lowered guards.